

Audit ChapExpress

2^e passe — 27 août 2026, 12h40 (UTC+1).
Source : code apps/* + Prisma, croisé avec docs/modules.md. Audit statique (pas de pentest réseau ni exécution des e2e).

Delta depuis 11h (même journée). Courses express a désormais des écrans client et livreur. Hub 4 services actif. Aucun des 6 hotfixes sécurité P0 (A01–A06) n’est dans le code. Nouvelle précision : aucune prise de course ne revalide la zone (V02b).



La doc de cadrage est en retard sur le code. CLAUDE.md dit encore « seul Repas est construit ». Le code livre les 4 services côté client/livreur. docs/modules.md se contredit (Emplettes coché, puis « Rien commencé »). Ne pas piloter le backlog uniquement sur CLAUDE.md.

1. Verdict

Les quatre services (Repas, Colis, Emplettes liste libre, Courses express) sont utilisables bout-en-bout côté client et livreur. L’app partenaires ne gère que les restaurants. L’admin est un squelette. Paiements réels, caisse livreur, temps réel, S3, Maps et offline IndexedDB manquent.

Hub 4 services

Repas

Colis + suivi public

Emplettes liste

Courses express

PWA sans offline

Admin vide

FedaPay / WS / S3 / Maps

2. Couverture F-xxx (84 items)

Fait = parcours utilisable bout-en-bout. Partiel = backend ou UI incomplet. +10 faits vs 11h (Courses express + hub).

Module	Fait	Partiel	Absent	Total
Client (F-CLI)	23	6	8	37
Restaurant (F-RES)	4	2	3	9
Commerce (F-COM)	0	0	8	8
Livreur (F-LIV)	5	4	2	11
Admin (F-ADM)	0	3	16	19
Total	32	15	37	84

Client

Utilisable : compte téléphone + mot de passe, hub 4 services, catalogue/fiche/panier Repas, suivi (polling), carnet au checkout, Colis (création, tarif, CR, programmation, interdits, suivi + lien public), Emplettes liste libre (budget, remplacements, pointage, décompte), Courses express (description, multi-étapes, tarif, suivi).

Trous pour une ouverture ville : pas d'OTP SMS, pas d'invité, Mobile Money sans Fedapay, pas de WebSocket/push, historique non unifié (/commandes = Repas seulement), pas de recommander / notation / notifs, pas de photo (S3), pas de catalogue Emplettes.

Restaurant

Commandes (polling), acceptation/refus, préparation/prêt, menu, rupture, horaires / fermeture temporaire. Manque : délai d'acceptation, alerte sonore, CA, relevés, WhatsApp de secours.

Commerce partenaire

Type commerce en base. L'app partenaires ne sert que les restaurants. Bloque F-CLI-29 (Emplettes catalogue).

Livreur

Disponibilité, files des 4 services, transitions de statut, OTP Colis (côté client), pointage Emplettes, liens Maps 2 points. Pas de portefeuille, pas de récap journalier, pas d'offline IndexedDB, pas de photo enlèvement/ticket. Les routes / et /mes-courses = Repas, pas Courses express (/courses-express).

Back-office

Aucune route admin. Pas de dispatch auto (RG-14), pas de caisse (RG-03), pas de reversement Colis (RG-04). Zones et taux existent en données seulement.

3. Vulnérabilités

Sain : Prisma paramétré (pas d'injection SQL), pas d'XSS HTML brut, prix Repas recalculés serveur, ownership des commandes, suivi public Colis en liste blanche (id, statut, taille, fragile, dates), register forcé en rôle client, bcrypt 12 rounds.

ID	Sévérité	Titre	Où	Pourquoi c'est exploitable
V01	Élevée	Preuve Colis contournable (OTP optionnel)	livrer()	Un livreur peut marquer livré avec seulement un nom de réceptionnaire. RG-07 n'est pas imposé.
V02	Élevée	Course Repas : lecture puis écriture	prendreEnCharge() repas	Colis/Emplettes/Courses utilisent updateMany atomique. Repas lit puis écrit : deux livreurs peuvent se disputer la même course.
V02b	Élevée	Zone non revalidée à la prise (4 services)	les 4 prendreEnCharge	La liste « disponibles » filtre par zone ; l'assignation ne le recontrôle pas. Un livreur qui connaît l'id peut prendre une course hors zone.
V03	Élevée	Pas de rate limit auth	POST /auth/login, /register	Force brute / énumération (409 si numéro déjà pris). Mot de passe min. 8 caractères.
V04	Élevée	CORS ouvert si CORS_ORIGINS vide	main.ts	origin: true reflète n'importe quel Origin. JWT 7 jours en localStorage.
V05	Élevée	JWT long, rôle figé, pas de révocation	JwtAuthGuard	Rôle lu dans le jeton, pas en base. Compte rétrogradé ou jeton volé valides jusqu'à 7 jours.
V06	Moyenne	Fiche restaurant publique trop large	findOnePublic()	GET /restaurants/:id expose userId, tauxCommission, GPS, zoneId.
V07	Moyenne	Messages Prisma exposés	all-exceptions.filter.ts	P2002/P2003/P2025 renvoient exception.message (schéma, contraintes).

ID	Sévérité	Titre	Où	Pourquoi c'est exploitable
V08	Moyenne	OTP Colis via Math.random	generateCodeOtp()	PRNG non crypto. Atténué par omit livreur, mais V01 rend le code optionnel.
V09	Moyenne	Plafonds livreur jamais appliqués	plafondAvance / plafondCaisse	Champs seedés, jamais lus. RG-02 / RG-14 non appliqués.
V10	Moyenne	Comptes démo + seed prod	prisma/seed.ts	Mot de passe demo12345. Seed non bloqué en production.
V11	Moyenne	PII avant acceptation	listes disponibles	Tout livreur de la zone voit nom, téléphone et adresses des commandes non prises.
V12	Faible	Pas de Helmet ni JWT global	main.ts	Nouvel endpoint oublié ouvert par défaut.
V13	Faible	Permissions seedées jamais évaluées	RolesGuard	15 codes d'action admin en seed ; seul le nom de rôle JWT compte.

4. Incohérences docs / code

Sujet	Doc / modèle	Code réel
CLAUDE.md	Seul Repas construit	4 services E2E client/livreur ; admin vide
modules.md Emplettes	Coché puis « Rien commencé »	API + écrans liste libre livrés
Phasage Q-01	Repas → Colis → Emplettes → Courses	Les 4 sont livrés (mode simplifié)
RG-08 commission	tauxCommission partenaire	15 % en dur dans create() Repas
F-CLI-06	Historique unifié	/commandes = Repas seulement
F-CLI-13	Options / suppléments	Modèle Plat plat, instructions texte
F-CLI-03	Carnet d'adresses	CRUD API + checkout ; raccourci hub désactivé
Invité	Champs invite au schéma	Tous les POST exigent un JWT client
RBAC	Permissions granulaires	Seed seulement, aucun endpoint admin
Plan P0 11h23	A01-A06 à merger	CORS, OTP, throttle, projection resto : inchangés

5. Règles métier vs code

Règle	Statut	Écart
RG-01 Paiement MoMo / espèces	Partiel	Mode stocké ; aucun appel agrégateur
RG-02 Plafond avance / caisse	Absent	Champs DB ignorés
RG-03 Clôture caisse	Absent	Pas d'admin, pas de mouvements
RG-04 CR Colis / reversement	Partiel	Encaissement saisi ; pas de reverse expéditeur
RG-05 Budget Emplettes	Fait (liste)	Blocage + validation client ; pas d'escalade Q-26
RG-06 Remplacements	Fait	Préférence par article
RG-07 Preuve livraison	Partiel	OTP ou nom ; photo/S3 absents ; nom suffit (V01)

Règle	Statut	Écart
RG-08 Commission	Partiel	15 % hardcodé
RG-14 Attribution	Partiel	Self-serve par zone à la liste seulement

6. Priorités avant ouverture ville (Repas + Colis)

1. Durcir auth : rate limit, CORS obligatoire, JWT plus court, rôle relu en base.
2. OTP Colis obligatoire ; prise Repas atomique ; revalider la zone dans les 4 prises de course.
3. Projeter GET /restaurants/:id (masquer userId / tauxCommission).
4. Ne pas ouvrir espèces / contre-remboursement sans portefeuille livreur (RG-02) et un minimum de back-office caisse.

Intégrations hors code : FedaPay, Web Push, WhatsApp/SMS, WebSockets, S3, Google Maps, offline livreur.

Plan d'action associé : vagues P0 (A01–A06) puis P1 (JWT, plafonds, commission, Helmet, PII).